

Gestão e Políticas de Segurança

quinta-feira, 9 de abril de 2026 09:23

Conceitos de políticas de segurança

- O formato de uma política de segurança pode ser a diferença entre o sucesso e o fracasso, não apenas da efetiva segurança física e cibernética de uma infraestrutura, mas da própria conscientização e educação de seus colaboradores.

A Política de Segurança da Informação (PSI) é um documento formal que estabelece diretrizes, regras, práticas e procedimentos que uma organização deve seguir para proteger suas informações, ativos de informação e sistemas de informações contra ameaças, violações de segurança e riscos. Essa política é uma parte fundamental da gestão da segurança da informação de uma empresa ou instituição e tem como objetivo garantir a confidencialidade, integridade, disponibilidade e autenticidade das informações.

A PSI descreve as responsabilidades dos funcionários e partes envolvidas, define os níveis de acesso aos recursos de informação, estabelece práticas de gestão de senhas, orienta sobre o uso de dispositivos e redes seguras, e determina como lidar com incidentes de segurança, entre outros aspectos.

Para que as políticas sejam mais bem estabelecidas e cumpridas, devem ser construídas de forma colaborativa, adequando-se à realidade da empresa e de seus funcionários. Há um esforço demandado para esclarecimento e conscientização constante, para que a segurança da informação se torne cultura da empresa.

Você deve construir as políticas de segurança com o apoio da alta direção da empresa. A própria norma ABNT NBR ISO/IEC 27001 (ISO 27001, 2013) diz que a alta direção deve estabelecer uma política de segurança da informação que:

- Seja apropriada ao propósito da organização.
- Inclua os objetivos de segurança da informação ou forneça a estrutura para estabelecer os objetivos de segurança da informação.
- Inclua um comprometimento para satisfazer os requisitos aplicáveis, relacionados à segurança da informação.
- Inclua um comprometimento para a melhoria contínua do sistema de gestão da segurança da informação.

Outro ponto importante que a norma ABNT NBR ISO/IEC 27001 estabelece é que a política de segurança da informação deve:

- Estar disponível como informação documentada.
- Ser comunicada dentro da organização.
- Estar disponível para as partes interessadas conforme apropriado.

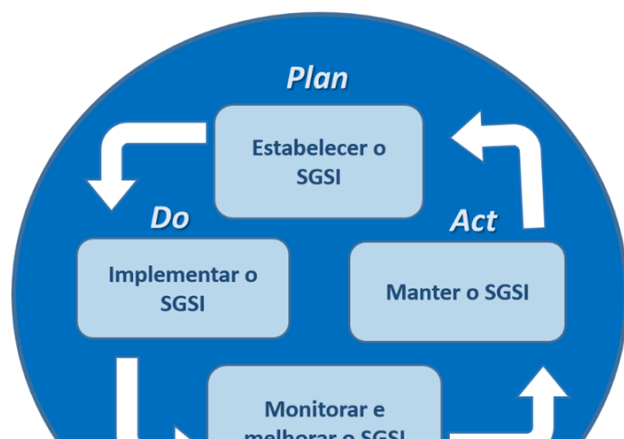
Seguindo esses pontos primordiais e elaborando as políticas de segurança de forma colaborativa e com divulgações constantes e de forma apropriada para todos os funcionários, você terá criado uma boa cultura e política de segurança da informação na sua empresa.

Normas para a segurança da informação

O sistema de gestão da segurança da informação (SGSI) preserva a confidencialidade, integridade e disponibilidade da informação por meio da aplicação de um processo de gestão de riscos e fornece confiança para as partes interessadas de que os riscos são adequadamente gerenciados.

É importante que um sistema de gestão da segurança da informação seja parte e esteja integrado aos processos da organização e com a estrutura de administração global e que a segurança da informação seja considerada no projeto dos processos, sistemas de informação e controles (ISO 27001, 2013).

Você deve especificar e implementar o SGSI de acordo com as características específicas da sua organização, que possui necessidades e objetivos, requisitos de segurança, processos organizacionais, funcionários, tamanho e estrutura da organização. Como esses fatores evoluem com o tempo, é preciso estabelecer, implementar, manter e melhorar continuamente um sistema de gestão da segurança da informação dentro do contexto da organização. Essa é uma das características principais dos sistemas de gestão, o processo de melhoria contínua, ou PDCA (*Plan, Do, Check, Act*), que pode ser visto na Figura 1.





- **Contexto da organização**, incluindo questões internas e externas relevantes para o seu propósito, os requisitos das partes interessadas, incluindo requisitos legais, regulatórios e contratuais. Escopo do SGSI.
- **Liderança**, com comprometimento da alta direção, estabelecimento de uma política de segurança da informação e atribuição de papéis, autoridades e responsabilidades.
- **Planejamento**, com ações para contemplar riscos e oportunidades, avaliação de riscos de segurança da informação, tratamento de riscos de segurança da informação e estabelecimento de objetivos de segurança da informação para as funções e níveis relevantes.
- **Apoio**, com provimento de recursos, criação de competências, conscientização e comunicação.
- **Operação**, com planejamento operacional e controle, avaliação de riscos de segurança da informação, tratamento de riscos de segurança da informação.
- **Avaliação de desempenho**, com monitoramento, medição, análise e avaliação, além de auditoria interna e análise crítica pela direção.
- **Melhoria**, com tratamento de não conformidades e ação corretiva, além de melhoria contínua



Família ISO 27.000, ISO 19.011 e LGPD

A Família ISO 27000, a ISO 19011, a Norma ISO 27002 e a LGPD (Lei Geral de Proteção de Dados) são importantes referências na área de segurança da informação e privacidade de dados, mas têm diferentes focos e objetivos.

Vamos compreender um pouco das convergências e divergências entre elas.

Família ISO 27000

ISO 27001: Define os requisitos para um Sistema de Gestão de Segurança da Informação (SGSI). Ajuda as organizações a estabelecerem e manterem um programa de segurança da informação eficaz. Você pode obter certificação dessa norma.

ISO 27002: Oferece diretrizes e melhores práticas para implementar controles de segurança da informação, complementando a ISO 27001.

ISO 27005: Foca na gestão de riscos de segurança da informação.

ISO 27701: Estende os princípios da ISO 27001 para abranger a privacidade de dados, com ênfase na proteção de dados pessoais.

Todas as normas da família ISO 27000 têm o objetivo de promover a segurança da informação e a gestão de riscos.

ISO 19011: Essa norma não trata diretamente da segurança da informação, mas sim da auditoria de sistemas de gestão. Ela fornece diretrizes sobre como auditar sistemas de gestão, incluindo SGSI baseados na ISO 27001. Ela pode ser usada para avaliar a conformidade com os requisitos da ISO 27001.

LGPD (Lei Geral de Proteção de Dados)

A LGPD é uma legislação brasileira que trata da proteção de dados pessoais. Ela se concentra na proteção da privacidade e nos direitos dos titulares de dados pessoais.

Embora a LGPD não seja uma norma técnica como as normas ISO, ela se relaciona com a proteção de dados pessoais, alinhada com a ISO 27701. Ambas visam a proteção da privacidade e dados pessoais, mas a LGPD é uma lei que impõe obrigações legais em organizações que tratam dados pessoais, enquanto as normas ISO são voluntárias e focadas em boas práticas.

Em resumo, as normas da família ISO 27000 tratam principalmente da segurança da informação e gestão de riscos, com a ISO 27701 estendendo essa abordagem para a privacidade de dados. A ISO 19011 concentra-se na auditoria de sistemas de gestão, incluindo SGSI. Por outro lado, a LGPD é uma legislação específica de proteção de dados pessoais no Brasil, impondo obrigações legais em

organizações que lidam com esses dados. Elas podem ser complementares em organizações que precisam atender a requisitos tanto de segurança da informação quanto de privacidade de dados.